MAXIMUM VALUE
FOR OUR CUSTOMERS

maxvalor

Network Vulnerability Scanner Report

✔ 192.168.88.100

Summary

Overall risk level:

High

Risk ratings:

Critical:	0
High:	7
Medium:	2
Low:	3
Info:	14

Scan information:

Start time:	Jan 27, 2026 / 17:54:54 UTC+01
Finish time:	Jan 27, 2026 / 19:40:25 UTC+01
Scan duration:	1 hrs, 45 min, 31 sec
Tests performed:	26/26
VPN Profile:	SZS
Scan status:	Finished

Findings

SMB Default Credentials - Bruteforce

CONFIRMED

port 445/tcp

We managed to detect that the target server is set up with a default credential pair.
We extracted the following information from the target: **192.168.88.100:445**

Username: **"administrator"**
Password: **"password"**

Details

Vulnerability description:

The Server Message Block (SMB) protocol is a network file-sharing protocol that allows applications to read and write files and to request services from server programs in a computer network. This vulnerability arises when an SMB service is configured with default credentials (such as username/password combinations that are the same as the factory settings or easily guessable). Attackers can exploit these known or weak default credentials to gain unauthorized access to shared resources, potentially leading to further malicious activities.

Risk description:

The presence of default credentials on the Server Message Block (SMB) service poses a significant security risk. Should an attacker successfully guess or know these default credentials, they could gain unauthorized access to shared files and directories. This initial access can lead to severe consequences, including the exfiltration of sensitive data, the ability to move laterally within the network to compromise other systems, the potential for denial-of-service attacks, and even full system compromise depending on the privileges associated with the default account. The ease with which these default credentials can often be discovered or are publicly known makes this a particularly attractive and exploitable vulnerability for malicious actors.

Recommendation:

We recommend to effectively address the risk of SMB default credentials. It is crucial to take immediate action. The most critical step is to change all default usernames and passwords associated with the SMB service to strong, unique alternatives that adhere to robust password policies. Furthermore, the principle of least privilege should be applied, ensuring that accounts accessing SMB shares only have the necessary permissions. Implementing network segmentation can also limit the blast radius should a compromise occur. Regular security audits are essential to continuously identify and rectify any instances of weak or default credentials. Finally, disabling the outdated SMBv1 protocol in favor of more secure versions like SMBv2 or v3 is highly recommended, and monitoring SMB traffic for any unusual activity can provide early warnings of potential breaches.

References:

https://nmap.org/nsedoc/scripts/smb-brute.html

SMB Default Credentials - Bruteforce

port 139/tcp

CONFIRMED

We managed to detect that the target server is set up with a default credential pair.
We extracted the following information from the target: **192.168.88.100:139**

Username: **"admin"**
Password: **"admin"**

Details

Vulnerability description:

The Server Message Block (SMB) protocol is a network file-sharing protocol that allows applications to read and write files and to request services from server programs in a computer network. This vulnerability arises when an SMB service is configured with default credentials (such as username/password combinations that are the same as the factory settings or easily guessable). Attackers can exploit these known or weak default credentials to gain unauthorized access to shared resources, potentially leading to further malicious activities.

Risk description:

The presence of default credentials on the Server Message Block (SMB) service poses a significant security risk. Should an attacker successfully guess or know these default credentials, they could gain unauthorized access to shared files and directories. This initial access can lead to severe consequences, including the exfiltration of sensitive data, the ability to move laterally within the network to compromise other systems, the potential for denial-of-service attacks, and even full system compromise depending on the privileges associated with the default account. The ease with which these default credentials can often be discovered or are publicly known makes this a particularly attractive and exploitable vulnerability for malicious actors.

Recommendation:

We recommend to effectively address the risk of SMB default credentials. It is crucial to take immediate action. The most critical step is to change all default usernames and passwords associated with the SMB service to strong, unique alternatives that adhere to robust password policies. Furthermore, the principle of least privilege should be applied, ensuring that accounts accessing SMB shares only have the necessary permissions. Implementing network segmentation can also limit the blast radius should a compromise occur. Regular security audits are essential to continuously identify and rectify any instances of weak or default credentials. Finally, disabling the outdated SMBv1 protocol in favor of more secure versions like SMBv2 or v3 is highly recommended, and monitoring SMB traffic for any unusual activity can provide early warnings of potential breaches.

References:

https://nmap.org/nsedoc/scripts/smb-brute.html

SMB Anonymous Access

port 139/tcp

CONFIRMED

We managed to detect a SMB Anonymous Access, using the following Request / Response chain.

Details

Vulnerability description:

Systems exposing the SMB/CIFS service (typically on TCP port 445) that allow unauthenticated or "null session" access can disclose available share names and system IPC endpoints (for example IPC$) to an attacker. The vulnerability arises when the SMB server permits anonymous listing of shares or grants access to sensitive shares without credentials. An attacker can enumerate shares remotely by connecting to the SMB service and issuing a share-listing request, with no prior authentication required. This behavior affects misconfigured SMB implementations and deployments where share permissions or server policy permit anonymous or guest access.

Risk description:

Unauthenticated share enumeration can reveal sensitive resources and configuration details, enabling targeted data access, credential harvesting, lateral movement, or the identification of writable/accessible shares for exfiltration or malware staging. The severity is high for systems that expose SMB to untrusted networks because exploitation requires only network connectivity to the SMB port and no user interaction.

Recommendation:

Disable anonymous or guest access in SMB configuration, restrict share permissions to authenticated users, and remove or harden publicly exposed shares; additionally, block or filter SMB (TCP/445) at network boundaries and perform an audit of share permissions to verify that only required principals have access.

References:

https://wadcoms.github.io/wadcoms/SMBClient-List-Shares-Anonymous/

SMB Anonymous Access

CONFIRMED

port 445/tcp

We managed to detect a SMB Anonymous Access, using the following Request / Response chain.

Details

Vulnerability description:

Systems exposing the SMB/CIFS service (typically on TCP port 445) that allow unauthenticated or "null session" access can disclose available share names and system IPC endpoints (for example IPC$) to an attacker. The vulnerability arises when the SMB server permits anonymous listing of shares or grants access to sensitive shares without credentials. An attacker can enumerate shares remotely by connecting to the SMB service and issuing a share-listing request, with no prior authentication required. This behavior affects misconfigured SMB implementations and deployments where share permissions or server policy permit anonymous or guest access.

Risk description:

Unauthenticated share enumeration can reveal sensitive resources and configuration details, enabling targeted data access, credential harvesting, lateral movement, or the identification of writable/accessible shares for exfiltration or malware staging. The severity is high for systems that expose SMB to untrusted networks because exploitation requires only network connectivity to the SMB port and no user interaction.

Recommendation:

Disable anonymous or guest access in SMB configuration, restrict share permissions to authenticated users, and remove or harden publicly exposed shares; additionally, block or filter SMB (TCP/445) at network boundaries and perform an audit of share permissions to verify that only required principals have access.

References:

https://wadcoms.github.io/wadcoms/SMBClient-List-Shares-Anonymous/

Vulnerabilities found for Apache HTTP Server 2.4.65

UNCONFIRMED

port 80/tcp

CVE	CVSS	EPSS Score	EPSS Percentile	CISA KEV	Summary	Exploit
CVE-2025-59775	7.5	0.00123	0.31865	No	Server-Side Request Forgery (SSRF) vulnerability in Apache HTTP Server on Windows with AllowEncodedSlashes On and MergeSlashes Off allows to potentially leak NTLM hashes to a malicious server via SSRF and malicious requests or content Users are recommended to upgrade to version 2.4.66, which fixes the issue.	N/A
CVE-2025-55753	7.5	0.00113	0.30286	No	An integer overflow in the case of failed ACME certificate renewal leads, after a number of failures (~30 days in default configurations), to the backoff timer becoming 0. Attempts to renew the certificate then are repeated without delays until it succeeds. This issue affects Apache HTTP Server: from 2.4.30 before 2.4.66. Users are recommended to upgrade to version 2.4.66, which fixes the issue.	N/A
CVE-2025-65082	6.5	0.00243	0.47312	No	Improper Neutralization of Escape, Meta, or Control Sequences vulnerability in Apache HTTP Server through environment variables set via the Apache configuration unexpectedly superseding variables calculated by the server for CGI programs. This issue affects Apache HTTP Server from 2.4.0 through 2.4.65. Users are recommended to upgrade to version 2.4.66 which fixes the issue.	N/A
CVE-2025-66200	5.4	0.00078	0.2327	No	mod_userdir+suexec bypass via AllowOverride FileInfo vulnerability in Apache HTTP Server. Users with access to use the RequestHeader directive in htaccess can cause some CGI scripts to run under an unexpected userid. This issue affects Apache HTTP Server: from 2.4.7 through 2.4.65. Users are recommended to upgrade to version 2.4.66, which fixes the issue.	N/A

Details

Risk description:

These vulnerabilities expose the affected applications to the risk of unauthorized access to confidential data and possibly to denial of service attacks. An attacker could search for an appropriate exploit (or create one) for any of these vulnerabilities and use it to attack

the system.

Notes:
- The vulnerabilities are identified based on the server's version.
- Only the first 5 vulnerabilities with the highest risk are shown for each port.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed "high" severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

We recommend you to upgrade the affected software to the latest version in order to eliminate the risks imposed by these vulnerabilities.

Classification:

EPSS score : 0.00243
EPSS percentile : 0.47312
CISA KEV: False
CVE : CVE-2025-66200, CVE-2025-65082, CVE-2025-59775, CVE-2025-55753
CVSS V3 : 7.5

Vulnerabilities found for Samba Smbd 4.6.2

port 139/tcp

UNCONFIRMED

CVE	CVSS	EPSS Score	EPSS Percentile	CISA KEV	Summary	Exploit
CVE-2022-45141	9.8	0.00577	0.68221	No	Since the Windows Kerberos RC4-HMAC Elevation of Privilege Vulnerability was disclosed by Microsoft on Nov 8 2022 and per RFC8429 it is assumed that rc4-hmac is weak, Vulnerable Samba Active Directory DCs will issue rc4-hmac encrypted tickets despite the target server supporting better encryption (eg aes256-cts-hmac-sha1-96).	N/A
CVE-2017-7494	9.8	0.94245	0.99923	Yes	Samba since version 3.5.0 and before 4.6.4, 4.5.10 and 4.4.14 is vulnerable to remote code execution vulnerability, allowing a malicious client to upload a shared library to a writable share, and then cause the server to load and execute it.	EDB-ID:42060 EDB-ID:42084
CVE-2017-14746	9.8	0.41219	0.97281	No	Use-after-free vulnerability in Samba 4.x before 4.7.3 allows remote attackers to execute arbitrary code via a crafted SMB1 request.	N/A
CVE-2023-3961	9.1	0.01941	0.83024	No	A path traversal vulnerability was identified in Samba when processing client pipe names connecting to Unix domain sockets within a private directory. Samba typically uses this mechanism to connect SMB clients to remote procedure call (RPC) services like SAMR LSA or SPOOLSS, which Samba initiates on demand. However, due to inadequate sanitization of incoming client pipe names, allowing a client to send a pipe name containing Unix directory traversal characters (../). This could result in SMB clients connecting as root to Unix domain sockets outside the private directory. If an attacker or client managed to send a pipe name resolving to an external service using an existing Unix domain socket, it could potentially lead to unauthorized access to the service and consequential adverse events, including compromise or service crashes.	N/A
CVE-2022-42898	8.8	0.08889	0.92341	No	PAC parsing in MIT Kerberos 5 (aka krb5) before 1.19.4 and 1.20.x before 1.20.1 has integer overflows that may lead to remote code execution (in KDC, kadmind, or a GSS or Kerberos application server) on 32-bit platforms (which have a resultant heap-based buffer overflow), and cause a denial of service on other platforms. This occurs in krb5_pac_parse in lib/krb5/krb/pac.c. Heimdal before 7.7.1 has "a similar bug."	N/A

Details

Risk description:

These vulnerabilities expose the affected applications to the risk of unauthorized access to confidential data and possibly to denial of service attacks. An attacker could search for an appropriate exploit (or create one) for any of these vulnerabilities and use it to attack the system.

Notes:
- The vulnerabilities are identified based on the server's version.
- Only the first 5 vulnerabilities with the highest risk are shown for each port.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed "high" severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

We recommend you to upgrade the affected software to the latest version in order to eliminate the risks imposed by these vulnerabilities.

Classification:

EPSS score : 0.94245
EPSS percentile : 0.99923
CISA KEV: True
CVE : CVE-2023-3961, CVE-2022-45141, CVE-2022-42898, CVE-2017-7494, CVE-2017-14746
CVSS V3 : 9.8

Vulnerabilities found for Samba Smbd 4.6.2

UNCONFIRMED

port 445/tcp

CVE	CVSS	EPSS Score	EPSS Percentile	CISA KEV	Summary	Exploit
CVE-2022-45141	9.8	0.00577	0.68221	No	Since the Windows Kerberos RC4-HMAC Elevation of Privilege Vulnerability was disclosed by Microsoft on Nov 8 2022 and per RFC8429 it is assumed that rc4-hmac is weak, Vulnerable Samba Active Directory DCs will issue rc4-hmac encrypted tickets despite the target server supporting better encryption (eg aes256-cts-hmac-sha1-96).	N/A
CVE-2017-7494	9.8	0.94245	0.99923	Yes	Samba since version 3.5.0 and before 4.6.4, 4.5.10 and 4.4.14 is vulnerable to remote code execution vulnerability, allowing a malicious client to upload a shared library to a writable share, and then cause the server to load and execute it.	EDB-ID:42060 EDB-ID:42084
CVE-2017-14746	9.8	0.41219	0.97281	No	Use-after-free vulnerability in Samba 4.x before 4.7.3 allows remote attackers to execute arbitrary code via a crafted SMB1 request.	N/A
CVE-2023-3961	9.1	0.01941	0.83024	No	A path traversal vulnerability was identified in Samba when processing client pipe names connecting to Unix domain sockets within a private directory. Samba typically uses this mechanism to connect SMB clients to remote procedure call (RPC) services like SAMR LSA or SPOOLSS, which Samba initiates on demand. However, due to inadequate sanitization of incoming client pipe names, allowing a client to send a pipe name containing Unix directory traversal characters (../). This could result in SMB clients connecting as root to Unix domain sockets outside the private directory. If an attacker or client managed to send a pipe name resolving to an external service using an existing Unix domain socket, it could potentially lead to unauthorized access to the service and consequential adverse events, including compromise or service crashes.	N/A
CVE-2022-42898	8.8	0.08889	0.92341	No	PAC parsing in MIT Kerberos 5 (aka krb5) before 1.19.4 and 1.20.x before 1.20.1 has integer overflows that may lead to remote code execution (in KDC, kadmind, or a GSS or Kerberos application server) on 32-bit platforms (which have a resultant heap-based buffer overflow), and cause a denial of service on other platforms. This occurs in krb5_pac_parse in lib/krb5/krb/pac.c. Heimdal before 7.7.1 has "a similar bug."	N/A

Details

Risk description:

These vulnerabilities expose the affected applications to the risk of unauthorized access to confidential data and possibly to denial of service attacks. An attacker could search for an appropriate exploit (or create one) for any of these vulnerabilities and use it to attack the system.

Notes:
- The vulnerabilities are identified based on the server's version.

- Only the first 5 vulnerabilities with the highest risk are shown for each port.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed "high" severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

We recommend you to upgrade the affected software to the latest version in order to eliminate the risks imposed by these vulnerabilities.

Classification:

EPSS score : 0.94245
EPSS percentile : 0.99923
CISA KEV: True
CVE : CVE-2023-3961, CVE-2022-45141, CVE-2022-42898, CVE-2017-7494, CVE-2017-14746
CVSS V3 : 9.8

SMB Signing Not Required

port 139/tcp

CONFIRMED

We managed to detect a SMB Signing Not Required, using the following Request / Response chain.

Details

Vulnerability description:

The SMB server accepts connections without requiring SMB packet signing, as indicated by the protocol metadata reporting signing as not required. This affects SMB protocol implementations that advertise SigningRequired=false during session negotiation and can include SMBv2 and later stacks when misconfigured. An unauthenticated remote attacker with network access between client and server can modify or replay SMB traffic, and may perform man-in-the-middle or relay attacks against clients and services that do not enforce signing. No local privileges on the target are required for an attacker who can intercept or manipulate network traffic to exploit this weakness.

Risk description:

An attacker able to intercept or manipulate network traffic can tamper with SMB sessions, capture or alter credentials, perform NTLM relay attacks, and gain unauthorized access to resources, leading to data exposure and lateral movement. The likelihood of exploitation is moderate to high in environments where clients and servers communicate over untrusted or flat networks without additional protections.

Recommendation:

Require and enforce SMB signing on servers and clients by enabling packet signing in the operating system or file server configuration (for example via Group Policy for Windows) and apply vendor guidance; additionally restrict SMB access to trusted networks and disable legacy SMB versions where possible.

References:

https://www.tenable.com/plugins/nessus/57608
https://nmap.org/nsedoc/scripts/smb2-security-mode.html

SMB Signing Not Required

port 445/tcp

CONFIRMED

We managed to detect a SMB Signing Not Required, using the following Request / Response chain.

Details

Vulnerability description:

The SMB server accepts connections without requiring SMB packet signing, as indicated by the protocol metadata reporting signing as not required. This affects SMB protocol implementations that advertise SigningRequired=false during session negotiation and can include SMBv2 and later stacks when misconfigured. An unauthenticated remote attacker with network access between client and server can modify or replay SMB traffic, and may perform man-in-the-middle or relay attacks against clients and services that do not enforce signing. No local privileges on the target are required for an attacker who can intercept or manipulate network traffic to exploit this weakness.

Risk description:

An attacker able to intercept or manipulate network traffic can tamper with SMB sessions, capture or alter credentials, perform NTLM relay attacks, and gain unauthorized access to resources, leading to data exposure and lateral movement. The likelihood of exploitation is moderate to high in environments where clients and servers communicate over untrusted or flat networks without additional protections.

Recommendation:

Require and enforce SMB signing on servers and clients by enabling packet signing in the operating system or file server configuration (for example via Group Policy for Windows) and apply vendor guidance; additionally restrict SMB access to trusted networks and disable legacy SMB versions where possible.

References:

https://www.tenable.com/plugins/nessus/57608
https://nmap.org/nsedoc/scripts/smb2-security-mode.html

End-of-Life (EOL) found for MySQL

port 3306/tcp

CONFIRMED

We managed to detect that MySQL has reached the End-of-Life (EOL).

Version detected: 5.5.5-10.11.14-mariadb-0%2Bdeb12u2
End-of-life date: 2020-04-11 Latest version for the cycle: 5.5.68
This release cycle (5.5) does have long-term-support (LTS). The cycle was released on 2012-04-11 and its latest release date was 2020-05-06.

Details

Risk description:

Using end-of-life (EOL) software poses significant security risks for organizations. EOL software no longer receives updates, including critical security patches. This creates a vulnerability landscape where known and potentially new security flaws remain unaddressed, making the software an attractive target for malicious actors. Attackers can exploit these vulnerabilities to gain unauthorized access, disrupt services, or steal sensitive data. Moreover, without updates, compatibility issues arise with newer technologies, leading to operational inefficiencies and increased potential for system failures.

Additionally, regulatory and compliance risks accompany the use of EOL software. Many industries have strict data protection regulations that require up-to-date software to ensure the highest security standards. Non-compliance can result in hefty fines and legal consequences. Organizations also risk damaging their reputation if a breach occurs due to outdated software, eroding customer trust and potentially leading to a loss of business. Therefore, continuing to use EOL software undermines both security posture and business integrity, necessitating timely upgrades and proactive risk management strategies.

Recommendation:

To mitigate the risks associated with end-of-life (EOL) software, it's crucial to take proactive steps. Start by identifying any EOL software currently in use within your organization. Once identified, prioritize upgrading or replacing these applications with supported versions that receive regular updates and security patches. This not only helps close security gaps but also ensures better compatibility with newer technologies, enhancing overall system efficiency and reliability.Additionally, develop a comprehensive software lifecycle management plan. This plan should include regular audits to identify upcoming EOL dates and a schedule for timely updates or replacements. Train your IT staff and users about the importance of keeping software up to date and the risks associated with using outdated versions. By maintaining a proactive approach to software management, you can significantly reduce security risks, ensure compliance with industry regulations, and protect your organization's reputation and customer trust.

SMB Shares - Enumeration

port 139/tcp

CONFIRMED

We managed to detect a SMB Shares - Enumeration, using the following Request / Response chain.
We extracted the following information from the target: **[print$ iszsnz IPC$ nobody]**

Details

Vulnerability description:

Remote SMB/CIFS services that implement the srvsvc MSRPC interface can disclose configured network shares by responding to NetShareEnumAll and NetShareGetInfo calls. An attacker with network access to TCP/445 can enumerate share names and retrieve metadata about each share when anonymous or provided credentials allow those calls. If direct enumeration is denied, the same disclosure can be attempted by probing a list of common share names. The issue relies on accessible SMB service endpoints and the presence of permissive share listing or authentication behavior.

Risk description:

Enumeration of shares can reveal exposed resources, share paths, and configuration details that facilitate information discovery and further exploitation, including unauthorized access or lateral movement. Although this behavior is primarily an information disclosure with generally low technical complexity, it increases the likelihood and speed of follow-on attacks against accessible shares.

Recommendation:

Limit SMB exposure by blocking or filtering TCP/445 from untrusted networks, remove or disable unnecessary shares, and enforce strong authentication and least-privilege access control on remaining shares. Monitor and log share access and enumeration attempts so suspicious activity can be detected and investigated.

References:

https://nmap.org/nsedoc/scripts/smb-enum-shares.html

SMB Shares - Enumeration

port 445/tcp

CONFIRMED

We managed to detect a SMB Shares - Enumeration, using the following Request / Response chain.
We extracted the following information from the target: **[print$ iszsnz IPC$ nobody]**

Details

Vulnerability description:

Remote SMB/CIFS services that implement the srvsvc MSRPC interface can disclose configured network shares by responding to NetShareEnumAll and NetShareGetInfo calls. An attacker with network access to TCP/445 can enumerate share names and retrieve metadata about each share when anonymous or provided credentials allow those calls. If direct enumeration is denied, the same disclosure can be attempted by probing a list of common share names. The issue relies on accessible SMB service endpoints and the presence of permissive share listing or authentication behavior.

Risk description:

Enumeration of shares can reveal exposed resources, share paths, and configuration details that facilitate information discovery and further exploitation, including unauthorized access or lateral movement. Although this behavior is primarily an information disclosure with generally low technical complexity, it increases the likelihood and speed of follow-on attacks against accessible shares.

Recommendation:

Limit SMB exposure by blocking or filtering TCP/445 from untrusted networks, remove or disable unnecessary shares, and enforce strong authentication and least-privilege access control on remaining shares. Monitor and log share access and enumeration attempts so suspicious activity can be detected and investigated.

References:

https://nmap.org/nsedoc/scripts/smb-enum-shares.html

Open ports discovery

CONFIRMED

Port	State	Service	Product	Product Version
22	open	ssh	OpenSSH	9.2p1 Debian 2+deb12u7
80	open	http	Apache httpd	2.4.65
139	open	netbios-ssn	Samba smbd	4.6.2
445	open	netbios-ssn	Samba smbd	4.6.2
3306	open	mysql	MySQL	5.5.5-10.11.14-MariaDB-0+deb12u2
5900	open	vnc	RealVNC Enterprise	5.3 or later

Details

Risk description:

This is the list of ports that have been found on the target host. Having unnecessary open ports may expose the target to more risks because those network services and applications may contain vulnerabilities.

Recommendation:

We recommend reviewing the list of open ports and closing the ones which are not necessary for business purposes.

phpMyAdmin Panel

port 80/tcp

CONFIRMED

We managed to detect a phpMyAdmin Panel.
We extracted the following information from the target: **5.2.1deb1**.
Endpoint: **http://192.168.88.100:80/phpmyadmin/**.

Details

Vulnerability description:

The phpMyAdmin web-based administration interface was identified by common indicators such as the login form fields and characteristic page elements (for example index.php with pma_username or pma_servername). Any publicly accessible phpMyAdmin installation exposes the database management login endpoint to remote HTTP(S) requests and may include multiple common deployment paths (e.g., /phpmyadmin/, /phpMyAdmin/). If credentials are weak, reused, or if the instance is misconfigured, an unauthenticated remote attacker can attempt credential-guessing, credential-stuffing, or exploit authenticated-only flaws to interact with the database. Presence of an exposed panel does not by itself indicate a specific code-level vulnerability, but it creates an entry point that attackers can target.

Risk description:

An exposed phpMyAdmin panel significantly increases the risk of unauthorized database access, data disclosure, or destructive actions (schema changes, data deletion) if credentials are compromised. Successful authentication or chained exploitation of authenticated vulnerabilities can lead to complete compromise of stored data and potentially the underlying host, making exploitation likelihood moderate to high for internet-accessible instances with weak protections.

Recommendation:

Restrict access to phpMyAdmin by network controls (IP allowlists or VPN), enforce strong unique credentials and multi-factor authentication, and apply timely software updates; if exposure is unnecessary, remove or disable the web interface from public access.

How to reproduce:

```
curl -X 'GET' \
-H 'Accept: */*' \
-H 'Accept-Language: en' \
-H 'User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0' 'http://192.168.88.100:80/phpmyadmin/'
```

smb2-capabilities - Enumeration

port 139/tcp

CONFIRMED

We managed to detect a smb2-capabilities - Enumeration, using the following Request / Response chain.
We extracted the following information from the target: **["DFSSupport","Leasing"]**

Details

Vulnerability description:

SMBv2/SMBv3 implementations expose a Capabilities field in the protocol negotiation response that enumerates supported features and dialect-specific behaviors. An unauthenticated remote actor can query the SMB negotiate/connection response over TCP port 445 to obtain a list of enabled capabilities for each supported dialect. The information reveals protocol features such as multi-channel, leasing, persistent handles, encryption support, and other extensions implemented by the server. An exposed capabilities list enables accurate fingerprinting of the SMB implementation and its supported feature set.

Risk description:

Disclosure of SMB capabilities does not directly grant access, but significantly reduces attacker uncertainty by revealing supported features and protocol behaviors, which can guide exploitation or chaining of other SMB vulnerabilities. Because the vector requires only network access to the SMB service, the likelihood of reconnaissance and targeted follow-up attacks is moderate to high in exposed environments.

Recommendation:

Restrict access to SMB services by blocking or filtering TCP/445 at network boundaries and applying network segmentation; disable unused SMB dialects and features on servers where feasible and keep SMB implementations updated with vendor fixes. Monitor and log SMB negotiation activity to detect suspicious scanning or fingerprinting attempts.

References:

https://nmap.org/nsedoc/scripts/smb2-capabilities.html

SMB Version

port 139/tcp

CONFIRMED

We managed to detect a SMB Version, using the following Request / Response chain.
We extracted the following information from the target: **SMB 2.1**

Details

Vulnerability description:

This finding identifies the Server Message Block (SMB) protocol version in use on a target system by querying the SMB service typically accessible on TCP port 445. The detection relies on the SMB negotiation phase where the server advertises its protocol version string and capabilities, allowing an enumerator to extract the Version.VerString value. The discovery applies to hosts running SMB services (Windows, Samba, embedded devices, or honeypots) that respond to standard SMB negotiation and information queries. No exploitation is performed; the outcome is an informational disclosure of protocol version and features.

Risk description:

Exposed SMB version information enables attackers to determine whether a target supports legacy, insecure SMB variants (for example SMBv1) or unpatched implementations, increasing the likelihood of targeted exploitation using known vulnerabilities. Information disclosure of protocol version is low-impact by itself but materially raises attack efficiency and prioritization for lateral movement, ransomware, or remote code execution attempts.

Recommendation:

Restrict SMB access to trusted networks and management hosts, disable legacy SMB protocol versions where possible, and apply vendor security updates and configuration hardening to SMB services. Regularly audit exposed services and block TCP port 445 at network boundaries unless explicitly required.

SMB2 Server Time

port 139/tcp

CONFIRMED

We managed to detect a SMB2 Server Time, using the following Request / Response chain.
We extracted the following information from the target: **SystemTime: 2026-01-27T18:39:16.000Z ServerStartTime: 2009-04-22T19:24:48.000Z**

Details

Vulnerability description:

Certain SMB2 servers disclose their current system time and server start time during the SMB negotiation phase. The server returns fields such as SystemTime and ServerStartTime over an unauthenticated connection to the SMB service (typically TCP/445). An attacker able to connect to the SMB endpoint can retrieve these timestamps remotely without credentials. This behavior is present in SMB2 implementations that expose negotiation metadata and requires only network access to the listening SMB port.

Risk description:

Information disclosure of system and uptime timestamps can aid an attacker in fingerprinting hosts, correlating events, planning timed attacks, or narrowing windows for exploitation and lateral movement. The likelihood of remote retrieval is high whenever the SMB service is reachable and permits unauthenticated negotiation, though the direct impact is low compared with code-execution flaws.

Recommendation:

Restrict access to SMB services from untrusted networks using firewalls or network segmentation and disable public exposure of TCP/445. Where possible enforce authentication and apply vendor-recommended configurations and updates to reduce unnecessary information leakage.

References:

https://nmap.org/nsedoc/scripts/smb2-time.html

SMB Version

port 445/tcp

CONFIRMED

We managed to detect a SMB Version, using the following Request / Response chain.
We extracted the following information from the target: **SMB 2.1**

Details

Vulnerability description:

This finding identifies the Server Message Block (SMB) protocol version in use on a target system by querying the SMB service typically accessible on TCP port 445. The detection relies on the SMB negotiation phase where the server advertises its protocol version string and capabilities, allowing an enumerator to extract the Version.VerString value. The discovery applies to hosts running SMB services (Windows, Samba, embedded devices, or honeypots) that respond to standard SMB negotiation and information queries. No exploitation is performed; the outcome is an informational disclosure of protocol version and features.

Risk description:

Exposed SMB version information enables attackers to determine whether a target supports legacy, insecure SMB variants (for example SMBv1) or unpatched implementations, increasing the likelihood of targeted exploitation using known vulnerabilities. Information disclosure of protocol version is low-impact by itself but materially raises attack efficiency and prioritization for lateral movement, ransomware, or remote code execution attempts.

Recommendation:

Restrict SMB access to trusted networks and management hosts, disable legacy SMB protocol versions where possible, and apply vendor security updates and configuration hardening to SMB services. Regularly audit exposed services and block TCP port 445 at network boundaries unless explicitly required.

SMB2 Server Time

port 445/tcp

CONFIRMED

We managed to detect a SMB2 Server Time, using the following Request / Response chain.
We extracted the following information from the target: **SystemTime: 2026-01-27T18:39:16.000Z ServerStartTime: 2009-04-22T19:24:48.000Z**

Details

Vulnerability description:

Certain SMB2 servers disclose their current system time and server start time during the SMB negotiation phase. The server returns fields such as SystemTime and ServerStartTime over an unauthenticated connection to the SMB service (typically TCP/445). An attacker able to connect to the SMB endpoint can retrieve these timestamps remotely without credentials. This behavior is present in SMB2 implementations that expose negotiation metadata and requires only network access to the listening SMB port.

Risk description:

Information disclosure of system and uptime timestamps can aid an attacker in fingerprinting hosts, correlating events, planning timed attacks, or narrowing windows for exploitation and lateral movement. The likelihood of remote retrieval is high whenever the SMB service is reachable and permits unauthenticated negotiation, though the direct impact is low compared with code-execution flaws.

Recommendation:

Restrict access to SMB services from untrusted networks using firewalls or network segmentation and disable public exposure of TCP/445. Where possible enforce authentication and apply vendor-recommended configurations and updates to reduce unnecessary information leakage.

References:

https://nmap.org/nsedoc/scripts/smb2-time.html

smb2-capabilities - Enumeration

port 445/tcp

CONFIRMED

We managed to detect a smb2-capabilities - Enumeration, using the following Request / Response chain.
We extracted the following information from the target: **["DFSSupport","Leasing"]**

Details

Vulnerability description:

SMBv2/SMBv3 implementations expose a Capabilities field in the protocol negotiation response that enumerates supported features and dialect-specific behaviors. An unauthenticated remote actor can query the SMB negotiate/connection response over TCP port 445 to obtain a list of enabled capabilities for each supported dialect. The information reveals protocol features such as multi-channel, leasing, persistent handles, encryption support, and other extensions implemented by the server. An exposed capabilities list enables accurate fingerprinting of the SMB implementation and its supported feature set.

Risk description:

Disclosure of SMB capabilities does not directly grant access, but significantly reduces attacker uncertainty by revealing supported features and protocol behaviors, which can guide exploitation or chaining of other SMB vulnerabilities. Because the vector requires only network access to the SMB service, the likelihood of reconnaissance and targeted follow-up attacks is moderate to high in exposed environments.

Recommendation:

Restrict access to SMB services by blocking or filtering TCP/445 at network boundaries and applying network segmentation; disable unused SMB dialects and features on servers where feasible and keep SMB implementations updated with vendor fixes. Monitor and log SMB negotiation activity to detect suspicious scanning or fingerprinting attempts.

References:

https://nmap.org/nsedoc/scripts/smb2-capabilities.html

SMB - Enumeration

port 139/tcp

CONFIRMED

We managed to detect a SMB - Enumeration, using the following Request / Response chain.
We extracted the following information from the target: **NetBIOSComputerName: VYCHSERVER, NetBIOSDomainName: VYCHSERVER, DNSComputerNamen: vychserver, DNSComputerName: vychserver, ForestName: , OSVersion: 6.1.0**

Details

Vulnerability description:

The SMB service exposes machine and domain metadata through unauthenticated SMB protocol calls (SMBv2 metadata enumeration) when the SMB port (TCP/445) is reachable. An attacker who can connect to the SMB endpoint can query fields such as OS version, NetBIOS and DNS computer names, domain names, and forest name. This information disclosure occurs without exploiting a software flaw; it relies on the SMB implementation permitting anonymous or unauthenticated metadata responses. The issue affects systems that expose SMB services to untrusted networks or allow anonymous/guest enumeration regardless of vendor or product version.

Risk description:

Exposed SMB metadata enables reconnaissance that significantly reduces attacker effort for targeted attacks, credential harvesting, and lateral movement inside a network. The severity is medium to high in environments where SMB is reachable from untrusted networks or where additional weak controls (guest access, missing firewall rules) exist, and exploitation likelihood is high whenever TCP/445 is exposed.

Recommendation:

Restrict remote access to SMB by blocking or filtering TCP/445 at network boundaries and apply network segmentation to isolate file-sharing hosts. Require authenticated access for SMB, disable anonymous/guest enumeration where possible, and monitor SMB traffic and authentication attempts for suspicious activity.

References:

https://nmap.org/nsedoc/scripts/smb-security-mode.html

SMB Operating System

port 139/tcp

CONFIRMED

We managed to detect a SMB Operating System, using the following Request / Response chain.
We extracted the following information from the target: **6.1.0**

Details

Vulnerability description:

The SMB service (typically TCP port 445) discloses operating system information through its SMB protocol metadata (SMBv1/SMBv2 responses). When an unauthenticated SMB connection is established, the server may return an OSVersion field that reveals specific Windows build and edition strings. This behavior affects hosts running SMB services across a wide range of Windows releases and any device implementing SMB that returns version metadata. The attack vector requires network connectivity to the SMB service (reachable port 445) but does not require valid credentials, making remote fingerprinting possible.

Risk description:

Exposing exact OS and build information enables attackers to precisely identify exploitable systems and tailor follow-on attacks, increasing the likelihood of successful exploitation. The severity is informational for disclosure itself but materially raises risk by reducing attacker reconnaissance effort and facilitating targeted exploitation of known vulnerabilities.

Recommendation:

Limit exposure of SMB services to untrusted networks by blocking or filtering TCP/445 at network boundaries and using network segmentation; disable legacy SMB versions when not required and ensure hosts are patched to current supported releases.

References:

https://nmap.org/nsedoc/scripts/smb-os-discovery.html

SMB - Enumeration

port 445/tcp

CONFIRMED

We managed to detect a SMB - Enumeration, using the following Request / Response chain.
We extracted the following information from the target: **OSVersion: 6.1.0, NetBIOSComputerName: VYCHSERVER, NetBIOSDomainName: VYCHSERVER, DNSComputerNamen: vychserver, DNSComputerName: vychserver, ForestName:**

Details

Vulnerability description:

The SMB service exposes machine and domain metadata through unauthenticated SMB protocol calls (SMBv2 metadata enumeration) when the SMB port (TCP/445) is reachable. An attacker who can connect to the SMB endpoint can query fields such as OS version, NetBIOS and DNS computer names, domain names, and forest name. This information disclosure occurs without exploiting a software flaw; it relies on the SMB implementation permitting anonymous or unauthenticated metadata responses. The issue affects systems that expose SMB services to untrusted networks or allow anonymous/guest enumeration regardless of vendor or product version.

Risk description:

Exposed SMB metadata enables reconnaissance that significantly reduces attacker effort for targeted attacks, credential harvesting, and lateral movement inside a network. The severity is medium to high in environments where SMB is reachable from untrusted networks or where additional weak controls (guest access, missing firewall rules) exist, and exploitation likelihood is high whenever TCP/445 is exposed.

Recommendation:

Restrict remote access to SMB by blocking or filtering TCP/445 at network boundaries and apply network segmentation to isolate file-sharing hosts. Require authenticated access for SMB, disable anonymous/guest enumeration where possible, and monitor SMB traffic and authentication attempts for suspicious activity.

References:

https://nmap.org/nsedoc/scripts/smb-security-mode.html

SMB Operating System

port 445/tcp

CONFIRMED

We managed to detect a SMB Operating System, using the following Request / Response chain.
We extracted the following information from the target: **6.1.0**

Details

Vulnerability description:

The SMB service (typically TCP port 445) discloses operating system information through its SMB protocol metadata (SMBv1/SMBv2 responses). When an unauthenticated SMB connection is established, the server may return an OSVersion field that reveals specific Windows build and edition strings. This behavior affects hosts running SMB services across a wide range of Windows releases and any device implementing SMB that returns version metadata. The attack vector requires network connectivity to the SMB service (reachable port 445) but does not require valid credentials, making remote fingerprinting possible.

Risk description:

Exposing exact OS and build information enables attackers to precisely identify exploitable systems and tailor follow-on attacks, increasing the likelihood of successful exploitation. The severity is informational for disclosure itself but materially raises risk by reducing attacker reconnaissance effort and facilitating targeted exploitation of known vulnerabilities.

Recommendation:

Limit exposure of SMB services to untrusted networks by blocking or filtering TCP/445 at network boundaries and using network segmentation; disable legacy SMB versions when not required and ensure hosts are patched to current supported releases.

References:

https://nmap.org/nsedoc/scripts/smb-os-discovery.html

OS Detection

UNCONFIRMED

Operating System	Accuracy
Windows	100%

Details

Vulnerability description:

OS Detection

Server software and technologies

port 80/tcp

UNCONFIRMED

Software / Version	Category
php PHP	Programming languages

Debian	Operating systems
Bootstrap 5.3.0	UI frameworks
Apache HTTP Server 2.4.65	Web servers
jsDelivr	CDN

Details

Vulnerability description:
We noticed that server software and technology details are exposed, potentially aiding attackers in tailoring specific exploits against identified systems and versions.

Risk description:
The risk is that an attacker could use this information to mount specific attacks against the identified software type and version.

Recommendation:
We recommend you to eliminate the information which permits the identification of software platform, technology, server and operating system: HTTP server headers, HTML meta information, etc.

Scan coverage information

List of tests performed (26/26)

- Performed OS detection
- Performed port discovery
- Scanned for MySQL technology to determine if it reached End-of-Life (EOL)
- Fingerprinted website for technologies
- Scanned for vulnerabilities in Apache HTTP Server
- Scanned for vulnerabilities in Samba Smbd
- Scanned for vulnerabilities in Samba Smbd
- Checked for SMB Default Credentials - Bruteforce
- Checked for phpMyAdmin Panel
- Checked for smb2-capabilities - Enumeration
- Checked for SMB Version
- Checked for SMB2 Server Time
- Checked for SMB Version
- Checked for SMB2 Server Time
- Checked for smb2-capabilities - Enumeration
- Checked for SMB Signing Not Required
- Checked for SMB - Enumeration
- Checked for SMB Operating System
- Checked for SMB Signing Not Required
- Checked for SMB - Enumeration
- Checked for SMB Operating System
- Checked for SMB Default Credentials - Bruteforce
- Checked for SMB Shares - Enumeration
- Checked for SMB Shares - Enumeration
- Checked for SMB Anonymous Access
- Checked for SMB Anonymous Access

Scan parameters

Target:	192.168.88.100
Preset:	Deep
Scanning engines:	Version_based, Sniper, Nuclei
Check alive:	True
Extensive modules:	True
Protocol type:	TCP
Ports to scan:	Top 5000 ports
CVEs:	
Requests per second:	-